RedTeam AI Labs

Enterprise AI Governance, Agentic Tool-Execution Assurance & Risk Management Platform

Founder: Sulisumen Peter
GitHub: github.com/sulisumenpeter/RedTeam-AI-Labs
Focus: Legal AI, Autonomous Agentic Systems & Regulated Verticals

1. EXECUTIVE OVERVIEW

RedTeam AI Labs is an integrated software platform that operationalizes trust, regulatory compliance, and safety assurance across the enterprise AI and autonomous agent lifecycle. While organizations are rapidly deploying Large Language Models (LLMs) and autonomous agent workflows for client intake, contract drafting, database queries, and external tool execution, traditional Governance, Risk, and Compliance (GRC) tools remain static spreadsheet questionnaires that cannot evaluate active model behavior. RedTeam AI Labs bridges this operational divide by uniting **policy-driven adversarial red-teaming** and **Agentic Tool-Execution Assurance (Model Context Protocol / MCP & OpenTelemetry trace inspection)** with **quantitative 5x5 risk registers**, **statutory framework cross-walking** (NIST AI RMF 1.0, EU AI Act Reg. 2024/1689, ISO/IEC 42001:2023, OECD AI, and OWASP Agentic Top 10 2026), and **tamper-evident SHA-256 audit trails**.

> **Core Architectural Tenet: "The LLM Proposes, the Backend Disposes."**
> Generative models are leveraged to adversarially probe and evaluate target systems, but all final risk scores, severity classifications, and policy determinations are strictly calculated by deterministic backend rules in PostgreSQL.

2. THE PROBLEM: THE ENTERPRISE AI & AGENTIC TRUST CRISIS

Production & Agentic Failure Modes

- **Autonomous Tool Misuse:** Destructive SQL, shell escapes, unapproved MCP tool execution, and bypassed Human-in-the-Loop gates.
- **Cross-Tenant BOLA / IDOR:** Object-level tenant parameter tampering exposing confidential client data.
- **Legal Hallucinations & Bias:** Fictitious statute citations, credential leaks, and demographic friction differentials.

Regulatory Penalties

- **EU AI Act (Reg. 2024/1689):** Mandatory pre-deployment testing and risk management for high-risk AI (fines up to €35M / 7% turnover).
- **Statutory Standards:** NIST AI RMF & ISO 42001 continuous empirical verification requirements.
- **Legal Ethics:** State Bar rules enforce non-delegable duties of supervision over autonomous legal AI.

The Post-Consolidation Tooling Void

- **Legacy GRC (OneTrust, Vanta):** Passive documentation tracking without live behavioral testing.
- **Developer CLI Fuzzers:** Isolated scripts lacking enterprise multi-tenant RBAC and audit vaults.
- **Urgent Independence Demand:** OpenAI's acquisition of Promptfoo creates immediate market demand for model-agnostic assurance.

3. KEY PLATFORM CAPABILITIES (SIX CORE MODULES)

1. AI & Agentic System Inventory

- Centralized asset registry tracking business/technical owners, versions, deployment tiers, and EU AI Act risk tiers (Minimal, Limited, High, Unacceptable).
- Supports targets: `SYNTHETIC`, `EXTERNAL_ENDPOINT`, `OPENAI_COMPATIBLE`, and `AGENTIC_MCP_ENDPOINT`.

2. 5x5 Quantitative Risk Register

- Mathematical risk calculation: `Inherent = Likelihood × Impact`; `Residual = Res. Likelihood × Res. Impact`.
- Native PostgreSQL generated columns compute risk scores directly in the database engine, avoiding client calculation drift.

3. Governance & 5-Framework Library

- Immutable, version-controlled policies with cryptographic SHA-256 hashing.
- Direct control mappings across **NIST AI RMF 1.0**, **EU AI Act** (Arts 9, 13, 14, 50), **ISO/IEC 42001**, **OECD AI**, and **OWASP Agentic Top 10** (ASI-01 to ASI-04).

4. Adversarial Red-Team & Agentic Fuzzing Engine

- 1 anchor + 4 variants compiled concurrently in <20s across 10 attack categories.
- Model Context Protocol (MCP) tool coercion, SQL/shell injection, and HITL bypass probing.
- Paired differential testing detecting subtle socioeconomic and demographic friction.

5. Incident Management & Trace Inspector

- 1-click promotion of critical findings into tracked incident records with corrective action plans.
- Automated regression retesting loop verifying fixes against original vulnerability vectors.
- Interactive **Visual MCP Tool Call & OpenTelemetry (OTel) Waterfall Inspector**.

6. Cryptographic Evidence Vault

- Append-only audit trail logging every governance action and test run with SHA-256 hashes.
- Attests both raw model text responses and structured `toolCalls` / `otelSpans`.
- 1-click export of signed PDF, XSS-sanitized interactive HTML, and JSON audit bundles.

4. TECHNICAL ARCHITECTURE & ENTERPRISE SECURITY

Full-Stack Core

- **Next.js 14 App Router** with standalone compilation and 20 prerendered static routes.
- **Supabase PostgreSQL** with Row Level Security (RLS) & transient retry backoff.
- **Parallelized AI Execution:** Concurrent test plan compilation via `Promise.all`.

Dual-Engine AI Pipeline

- **Deterministic:** 9 zero-latency heuristic rules catching UPL, eviction advice, leaks, `UNAUTHORIZED_AGENTIC_TOOL_EXECUTION`, cross-tenant BOLA, FCRA lending redlining, and clinical triage safety.
- **Semantic:** Gemini Pro structured evaluation with 2500ms circuit breaker.
- **Severity Mapper:** Deterministic disposal capping proposal signals.

Hardened AppSec

- **Kernel-Level SSRF Guard:** Blocks 127.0.0.1, RFC-1918, metadata (169.254.169.254), decimal IPs, admin ports.
- **4-Tier RBAC:** Owner, Admin, Assessor, Viewer roles with strict workspace perimeter isolation.
- **Session Shield:** Resilient cookie management under rate limits.

5. MARKET BEACHHEAD & PROPOSED COMMERCIAL MODEL

Initial Beachhead: Legal AI & Legal Tech

Legal technology is our initial wedge because AI errors create immediate malpractice liability, ethics violations, and statutory exposure (Unauthorized Practice of Law, unlawful evictions). Law firms and legal tech vendors urgently require empirical safety proof before deploying client-facing assistants.

Expansion Verticals: Fintech (FCRA/ECOA lending bias), Clinical Healthcare (HIPAA/FDA triage safety), HR Talent Tech (EEOC compliance), and Autonomous Enterprise Agents.

Tier	Target Customer	Indicative Pricing
Community	Open-source devs, researchers	Free (up to 50 runs/mo)
Professional	Legal tech startups, boutique firms	$499 / month
Enterprise	Large law firms, corporate legal depts	$2,500+ / month
Assessor	Compliance auditors, consultants	$999 / seat / mo

**Note: Pricing and tiers are proposed models subject to pilot customer validation.*

6. CURRENT PROGRESS & EMPIRICAL VALIDATION

63 / 63	15 / 15	19	0
Unit & Agentic Tests Passing (100%)	Playwright E2E Tests (100%)	Supabase DB Tables Active	Browser Console / Build Errors

Verified Quality: 100% pass rate across 12 unit test suites and 4 Playwright E2E specs; Next.js 14 standalone build optimizes 20 static pages; live AI testing verified with Google Gemini and Model Context Protocol (MCP) telemetry; showcased at the **LexHack Builders Fellowship** evaluation.

7. 3–6 MONTH ROADMAP & PARTNERSHIP / FUNDING REQUEST

3–6 Month Roadmap

- **Months 1–2:** AWS Bedrock & Azure AI Foundry adapters; Claude 4/Sonnet, Llama 4, Gemini 2.5 Pro; live MCP server proxy interceptor; GitHub Actions CI/CD runner.
- **Months 3–4:** Deploy 3–5 legal tech & fintech design partner pilots; State Bar ethics & OWASP Agentic templates; SOC 2 Type I readiness.
- **Months 5–6:** Self-serve Stripe billing, real-time Slack/Teams/PagerDuty webhooks, continuous OTel production trace assurance.

The Request (Support & Infrastructure)

- **Cloud & AI Programs:** AWS Activate credits, Microsoft for Startups Founders Hub (Azure OpenAI), Google for Startups (Vertex AI enterprise tier).
- **Model Access Grants:** Developer credits from OpenAI, Anthropic & Google Cloud.
- **Design Partnerships:** 3–5 legal tech startups, boutique firms & fintechs.
- **Capital Focus:** 45% AI Compute & Cloud; 35% Engineering & AppSec; 20% Pilot Deployment.

8. LONG-TERM VISION

Just as Datadog became the industry standard for cloud observability and Vanta automated SOC 2 compliance, **RedTeam AI Labs** is building the indispensable assurance operating system every enterprise must run before deploying autonomous AI systems and agentic tools into the hands of real users.